University of Roehampton London

ASSESSMENT BRIEF - Resit Coursework

Programme	BEng Software Engineering BEng Software Engineering (with Foundation Year) BSc Cyber Security BSc Cyber Security (with Foundation Year)		
Module Title	Secure Software Development		
Module Code	CMP-X306		
Module Level	6	**Assessment Type(s)**	Resit Coursework
Word Length / Duration	Maximum 4000 words (Group Submission) 1000 (Individual Submission)	**% contribution to module mark**	100%
Deadline (date & time) for Submission	05/01/2027	**Format/Location of submission**	Moodle
Assessment Feedback date:	26/01/2027		

Learning Outcomes

This assessment has been designed to provide you with an opportunity to demonstrate your achievement of the learning outcomes listed below.

By successfully completing this assessment, you will be able…

- LO1) Identify and manage security risks as part of a software development project
- LO2) Critically analyse secure software development problems and determine appropriate methodologies,

Employability and Professional Skills

This assessment has been designed to provide you with an opportunity to demonstrate your achievement of the following skill(s) which is(are) critical in professional context and jobs.

By successfully completing this assessment, you will be able to …

- Conduct security assessments using industry-standard methodologies and tools (SAST/DAST, threat modelling, CVSS scoring)
- Develop proof-of-concept exploits and security patches in controlled environments

tools, and techniques (including program design and development) to solve them • LO3) Design and develop/adapt computer programs and to produce a solution that meets the design brief and critically evaluate solutions that are produced • LO4) Systematically develop and implement the skills required to be an effective member of a development team in a virtual professional environment, adopting real-life perspectives on team roles and organisation.	• Analyse software supply chains and assess dependency vulnerabilities using SBOMs and SCA tools • Identify, prioritise, and document security risks with evidence-based risk assessments • Communicate complex security findings through professional written reports and video demonstrations • Deploy and configure containerised application environments for security testing • Work effectively in role-based security teams with coordinated project management • Apply ethical security research practices and responsible vulnerability disclosure protocols

Assessment Overview

You will develop a web application or a mobile application. You will then conduct a **security assessment** of this application. All work will be performed in isolated test environments using industry-standard security tools and methodologies. This enforces ethical testing practices whilst developing professional security assessment skills.

Team Assessment Artefacts (what you need to submit)

1. Scoping Document –15 marks

- Information about the application
- Initial observations about the application architecture
- Planned assessment approach and methodology
- Evidence of local deployment (screenshots)
- Local instance deployment evidence (screenshots)
- Initial reconnaissance and scoping document

2. Threat Model – 35marks

A comprehensive threat model, demonstrating systematic security analysis.

Required Content:

- Threat model using recognised methodology (STRIDE, PASTA, DREAD, etc.)
- Attack surface analysis specific to chosen domain
- Risk matrix identifying 3-5 prioritised threats
- Detailed attack scenarios with exploitability assessment
- Impact analysis with business context
- Testing plan development
- Risk Register

3. Basic Security Assessment Report – 35 marks

You will perform a lightweight security review across the following four areas. Document every finding with a screenshot and terminal output, written up in a pentest finding style.

- Authentication & Session Testing
- Unauthenticated Access to any API Endpoints
- Basic Input Validation (XSS probe)
- HTTP Security Headers Check
- SSL/TLS Testing
- OWASP top 10

Write a report covering:

- **What you tested and how.**
- **Findings:** What you found (pass or fail or partial for each)
- **Evidence:** Screenshots, code analysis, logs demonstrating vulnerabilities
- **CVSS Scoring:** Accurate severity classification for each weakness
- **Remediation:** one recommendation for any weakness discovered

Individual Assessment Artefacts

4. *Reflection – 15 marks*

A critical analysis of your personal contribution, demonstrating role-specific learning and professional development, and appraisal of the rest of the group.

Resources and Support

Recommended Documentation

- OWASP Testing Guide: https://owasp.org/www-project-web-security-testing-guide/
- Portswigger academy: https://portswigger.net/web-security
- CVSS Calculator: https://www.first.org/cvss/calculator/3.1
- STRIDE Threat Modelling: Microsoft Security Development Lifecycle
- Burp Suite Documentation: https://portswigger.net/burp/documentation

Indicative Tools & Platforms

- Docker (for application deployment)
- VirtualBox or VMware (for isolated testing)
- OBS Studio or Loom (for video recording)
- GitHub (for version control and collaboration)
- Module VLE resources (threat model templates, report examples)

Learning Resources

- PortSwigger Web Security Academy (free online training)
- OWASP Juice Shop (practice vulnerable application)
- HackTheBox Academy (security training platform)
- Module VLE tutorials (security tool guides, video recording guide)

Documentation Standards

- **Report Format:** All reports in PDF format with proper structure

- **Evidence:** Screenshots must include timestamps and system context
- **Code Samples:** All code properly formatted with syntax highlighting
- **References:** IEEE referencing style required

Prohibited Activities

The following activities are **strictly prohibited** and will result in academic misconduct proceedings:

- **Testing production systems:** Never test live systems or public-facing applications
- **Public disclosure:** Do not publicly disclose vulnerabilities before assessment completion
- **Malicious activity:** No actual exploitation beyond controlled test environments
- **University network testing:** Never conduct security tests on university infrastructure
- **Unauthorised testing:** Only test systems explicitly approved for this coursework
- **Testing only using AI:** Can be used, if documented, as part of a manual testing methodology

Use of Artificial Intelligence (AI)

In this section include details of the use of AI tools to support the assessment.

https://roehamptonprod.sharepoint.com/sites/portal/information/LTEU/Documents/4a%20AI%20principles%20and%20guidance%20-for%20Senate.docx

https://roehamptonprod.sharepoint.com/sites/portal/information/LTEU/Documents/4b%20Student%20Guidelines%20on%20the%20use%20of%20AI_.docx

The assessment is designed so that the use of AI during the assessment is possible. You must acknowledge any use of AI and appropriately cite all AI generated outputs. Please make sure you read and understand the assessment guidelines and ask your Module Leader if you have any questions. You can find the guidance on the use of AI.

Referencing

IEEE style: https://www.citethemrighttutorial.com/course-modules/ieee

Mitigating circumstances/late penalties

Sometimes circumstances outside of your control may affect your studies and might prevent you from submitting work on time or attending an exam.

The University offers the ability for students to request additional time to complete an assessment or to defer an examination to a later date. If you are finding yourself in such a situation, please speak to your Academic Guidance Tutor, the Roehampton Student Union

(RSU) or someone in the **Wellbeing team** first, who can support you. Further details can be found on the mitigating circumstances portal.
Submission Checklist Before you submit, ask yourself: Have I fully answered the assessment brief? Have I met the word count and formatting requirements? Is my referencing complete and accurate? Have I declared any AI use honestly? Have I proofread my work? Am I submitting through the correct platform before the deadline?